Cloud Scanner and GRC Workshop: From Security Findings to Audit Evidence

Duration: 2.5–3 hours, including a 10-minute break.
Platform: CloudGuard scanner and the connected GRC platform.
Audience: Cloud/DevOps engineers, security analysts, GRC practitioners, and technical students.
Level: Beginner to intermediate; assumes basic awareness of cloud accounts, resources, and permissions.
Format: Short explanations, live demonstrations, guided exercises, and a shared case study.

The workshop follows one practical workflow: identify a cloud weakness, scan it, interpret the finding, attach evidence to a control, record the business risk, assign remediation, and verify the result.

By the end, participants should be able to:

- Explain the roles of a cloud scanner and Governance, Risk, and Compliance (GRC).
- Select a scan target and scope, launch a scan, and read the results.
- Prioritize findings using exposure, asset importance, and business impact alongside severity.
- Link scanner evidence to a relevant control and record an associated risk.
- Define remediation ownership, a due date, and evidence needed for closure.
- Explain why a successful scan alone does not establish overall compliance.

Timed syllabus

Module	2.5-hour version	3-hour version	Topics and activity	Participant outcome
1. Cloud security and GRC foundations	15 min	15 min	Shared responsibility; misconfiguration versus software vulnerability; governance, risk, and compliance; scanner-to-GRC workflow	Explain how a technical finding becomes a governance action

Module	2.5-hour version	3-hour version	Topics and activity	Participant outcome
2. Cloud scanner walkthrough	20 min	20 min	Dashboard; target and credential selection; scan scope; AWS, GCP, Kubernetes, and IaC coverage overview; scan status and reports	Understand the workflow and choose a suitable target
3. Guided scanning exercise	25 min	35 min	Launch a scan against a prepared sandbox or sample IaC target; inspect asset IDs, findings, and evidence; review a completed scan if the live job is still running	Produce or inspect a scan result and identify three findings
4. Finding analysis and prioritization	20 min	20 min	Severity; exposure; asset sensitivity; business impact; false positives; remediation advice; vulnerability versus risk	Rank three findings and justify what should be fixed first
Break	10 min	10 min	Short break	—

Module	2.5-hour version	3-hour version	Topics and activity	Participant outcome
5. GRC controls, evidence, and risk management	30 min	40 min	Framework/control navigation; CloudGuard connector; evidence provenance and review; control mapping; risk register and treatment; ownership and due dates	Link one finding to a control, evidence artifact, and risk record
6. End-to-end remediation and reporting	20 min	30 min	Assign the fix; document treatment or an exception; examine before/after evidence; rescan or review a prepared rescan; discuss closure and reports	Complete a finding-to-remediation case and explain its audit trail
7. Knowledge check and Q&A	10 min	10 min	Short questions, participant walkthrough, and open discussion	Describe the complete scanner-to-GRC workflow
Total	**150 min**	**180 min**		

For the three-hour delivery, the running order is: foundations 00:00–00:15; scanner walk-through 00:15–00:35; scanning exercise 00:35–01:10; prioritization 01:10–01:30; break 01:30–01:40; GRC exercise 01:40–02:20; remediation and reporting 02:20–02:50; Q&A 02:50–03:00.

Module delivery details

1. **Cloud security and GRC foundations**
   - Introduce identity, network, storage, workload, and logging weaknesses with simple examples.

- Explain governance as accountability and policy, risk as potential business harm, and compliance as meeting applicable requirements with evidence.
- Use an exposed storage configuration as the running example. Ask participants to identify the asset, possible impact, and likely owner.

2. **Cloud scanner walkthrough**
   - Show login, dashboard navigation, target selection, credentials, scan creation, progress, findings, and reporting.
   - Explain scan boundaries and the permissions needed to inspect a target.
   - Briefly explain that specialized tools can supply different finding types, such as configuration issues, vulnerable dependencies, or exposed secrets.
   - Keep the main demonstration on one prepared target. Other supported targets receive an overview.
3. **Guided scanning exercise**
   - Use a prepared cloud sandbox with appropriate scanning permissions, or the project's sample IaC lab when cloud access is unavailable.
   - Launch the scan and inspect the target scope and job status.
   - Review three representative issues: exposed storage configuration, an overly permissive identity policy, and an open administrative network rule.
   - Record the finding ID, affected asset, severity, evidence, and proposed fix.
   - **Extra 10 minutes:** compare cloud findings with a sample IaC scan and discuss what each scan can establish.
4. **Finding analysis and prioritization**
   - Compare scanner severity with contextual priority.
   - Discuss reachability, sensitive data, asset importance, existing safeguards, and confidence in the evidence.
   - Have small groups rank three findings and state the reason for their first choice.
   - Explain that a finding describes a detected condition; a risk record describes a scenario and its potential impact.
5. **GRC controls, evidence, and risk management**
   - Show the framework and control views using a framework already configured for the demonstration.
   - Trace a CloudGuard finding through the connector/evidence view. Use a prepared imported record if live synchronization is unavailable.
   - Review the asset, source, timestamp, scan/finding references, evidence artifact, and reviewer status.
   - Map the finding to a relevant control using the actual wording in the configured framework.
   - Draft a risk statement with an owner, likelihood/impact rationale, treatment, and due date.
   - Explain evidence freshness and the difference between automated technical evidence and evidence that requires human review.
   - **Extra 10 minutes:** participants review one evidence item and compare their control mapping and treatment decisions.
6. **End-to-end remediation and reporting**
   - Continue the same case from finding to control, evidence, risk, and remediation.

- Record the technical owner and completion criteria.
- Show a prepared corrected configuration and a follow-up scan, or demonstrate the correction in the sandbox if time permits.
- Compare before/after evidence and explain what is needed before marking the issue resolved and reviewing the affected control.
- Discuss the different information needed by engineers, management, and auditors.
- **Extra 10 minutes:** demonstrate a fix and rescan in the prepared lab; use saved results if scan execution exceeds the slot.

7. **Knowledge check and Q&A**
   - What does a scanner finding establish, and what further context is needed?
   - Which evidence would support the selected control?
   - Who owns remediation, and what proves closure?
   - Why might a high-severity finding have a different remediation priority from another high-severity finding?

Shared case study and participant deliverable

Scenario: a scan flags a cloud storage configuration that may permit public access. Participants inspect the evidence and confirm the exposure, describe a potential data-disclosure scenario, select a relevant access-control requirement, assign an owner and due date, propose a correction, and identify the follow-up evidence needed for closure. Use dummy data in the demonstration.

Each participant or group completes one worksheet:

Finding / asset	Evidence and timestamp	Severity and priority rationale	Relevant control	Risk scenario and impact	Owner / due date	Treatment	Verification and closure evidence

Completion means the group can explain its priority choice, control mapping, treatment, and closure evidence. A control may require additional evidence beyond this single finding.

Preparation

- Participants need a laptop, browser, and access to the prepared scanner/GRC demo environment; individual cloud accounts are optional.
- The trainer prepares the environment before the workshop, including demo logins, a scoped target, the configured framework, and one sample risk/evidence record.
- Prepare a completed scan with three useful findings, a sample IaC file, before/after evidence, and a sample report as fallbacks.
- Rehearse the connector and evidence workflow against the deployed build. Demonstrate manual attachment/mapping where an automated step is unavailable.
- Use an isolated sandbox for live changes and confirm cleanup after the demonstration. Keep environment provisioning outside the workshop agenda.

- For 150 minutes, use prepared before/after results in Module 6. For 180 minutes, include the extra scan comparison, evidence-review exercise, and remediation demonstration.